

SkillSync Nexus

Complete Enterprise Production & Security Roadmap

Production Guide 2026

Document Purpose: Yeh comprehensive checklist aur engineering architecture guide hai. Hackathon MVP se nikal kar jab SkillSync Nexus ko live enterprise colleges (10,000+ students) aur corporate recruiters ke liye launch karenge, toh in sabhi points ko step-by-step implement karna hai.

1. Executive Summary: Current MVP vs Production Target

Hamara current hackathon prototype functional aur interactive hai (React 18 + Node.js/Express + Supabase Cloud + Local Circuit Breaker). Production transition me hume **Zero-Trust Security**, **ACID transactional reliability**, aur **High-Concurrency Scaling** add karni hai.

Area	Current MVP State	Production Target Requirement
Authentication	Plain demo credentials & client state	Bcrypt (Salt 12) + HttpOnly JWT + 2FA / OTP
API Security	CORS enabled + basic null checks	Rate Limiting + Helmet.js + Zod input sanitization
Database Scaling	Direct REST calls + fallback JSON	PgBouncer Connection Pooling + Redis Caching + B-Tree Indexing
File Storage	In-browser sandbox memory buffer	AWS S3 / Supabase Storage with presigned URLs & virus scanning
Compliance	Role-based dashboards (RBAC)	DPDP Act 2023 / GDPR + Audit logs + Right to be Forgotten

2. Phase 1: Security & Authentication Hardening (OWASP Top 10)

2.1 Password Hashing & Safe Credential Storage

- Implement bcrypt / argon2id:** Users ke raw passwords database me kabhi save nahi honge. `const hash = await bcrypt.hash(password, 12);` use karein.
- Password Complexity Rules:** Minimum 8 characters, at least 1 uppercase, 1 lowercase, 1 number aur 1 special character enforce karein.
- Credential Stuffing Prevention:** Compromised passwords check karne ke liye HIBP (HaveIBeenPwned) API verify karein.

2.2 Rate Limiting & Brute-Force Defense

- Login Endpoint Rate Limiting:** `express-rate-limit` lagayein. Max 5 failed attempts per IP within 15 minutes, jiske baad account temporary lockout hoga.
- Global API Throttling:** Normal users ke liye 100 requests per minute limit set karein taaki DDoS aur automated scraping block ho.
- Redis-Backed Rate Store:** Multi-server horizontal scaling ke waqt centralized rate counters Redis me store karein.

2.3 Session Architecture: HttpOnly JWT & Refresh Token Rotation

- **No localStorage Tokens:** Sensitive JWT tokens ko `localStorage` me rakhne se XSS attacks ka khatra hota hai. Hamesha `HttpOnly, Secure, SameSite=Strict` cookies use karein.
- **Short-Lived Access Tokens:** Access token ki expiry 15 minutes rakhein. Refresh token ki expiry 7 days with automatic rotation.
- **Server-Side Token Revocation:** Logout ya password change par database me stored refresh token invalidate karein.

2.4 Multi-Factor Authentication (MFA / 2FA)

- **TOTP Support:** Google Authenticator / Microsoft Authenticator ke through 6-digit TOTP enable karein (Supabase Auth built-in MFA use karein).
- **Backup Emergency Codes:** User ko 8-10 one-time recovery codes provide karein.

SkillSync Nexus

Production Roadmap & Technical Specification

Page 2 of 3

2.5 HTTP Security Headers & Payload Sanitization

- **Helmet.js Integration:** Express me `app.use(helmet());` lagayein jo automatically Content Security Policy (CSP), HSTS (Strict-Transport-Security), aur X-Frame-Options (Clickjacking defense) set karta hai.
- **Strict CORS Whitelisting:** Wildcard `origin: '*'` ko strictly restrict karein verified production domain par:
`origin: ['https://skillsync.edu.in']`.
- **Input Validation via Zod / Joi:** Har API body parameter ka strictly type, length, aur regex sanitize karein taaki SQL/NoSQL Injection aur Prototype Pollution rok sakein.

3. Phase 2: Database & Concurrency Scaling (10,000+ Students)

3.1 Connection Pooling via PgBouncer

- PostgreSQL me har naya client connection 2–10 MB RAM consume karta hai. Direct connection se 1,000 students ek saath aate hi database crash ho sakta hai.
- **Solution:** Supabase / AWS RDS ke aage **PgBouncer (Transaction Pooling)** enable karein jo 10,000+ concurrent requests ko 50–100 active connections me pool karta hai.

3.2 Database Indexing & JSONB Optimization

- **B-Tree Indexes:** High-traffic lookup columns par index create karein:
`CREATE INDEX idx_students_email ON students(email);`
`CREATE INDEX idx_students_college ON students(college);`
- **GIN Indexes for JSONB:** Resume skills aur projects search ke liye:
`CREATE INDEX idx_students_skills ON students USING gin (skills);`

3.3 In-Memory Caching (Redis)

- Placement season me jobs list aur recruiter search bar-bar database se query karne ke bajaye Redis me 5 minute TTL (Time-To-Live) ke sath cache karein.
- Isse database ka CPU load **75% se 85% tak drop** ho jata hai aur API latency < 30ms ho jati hai.

3.4 Automated Backups & Disaster Recovery

- Automated Daily Snapshots + 7-day Point-In-Time Recovery (PITR) enable karein.
- Secondary read-replica region me multi-AZ failover setup karein.

4. Phase 3: Storage & File Handling Infrastructure

- **Dedicated Cloud Object Storage:** Local memory buffer ki jagah AWS S3 ya Supabase Storage bucket use karein.
- **Presigned URLs:** User direct browser se S3 par upload karega using pre-signed temporary credentials, taaki Express backend par file processing ka load na pade.
- **Malware & Virus Scanning:** Uploaded resume files ko background worker me ClamAV / AWS GuardDuty se scan karein.
- **Magic Bytes Validation:** Extension (.pdf) par bharosa na karein; binary header signatures (`%PDF-`) verify karein aur max limit 5MB enforce karein.

5. Phase 4: Observability, Logging & Audit Trails

- **Structured JSON Logging (Pino / Winston):** Standard `console.log` hata kar structured JSON logging use karein jisme timestamp, correlation ID, user ID, aur request path logged ho.
- **Sentry Real-Time APM:** Frontend (React) aur Backend (Express) dono me Sentry plug-in karein taaki live user crash turant Slack/Email par alert de.
- **Immutable Audit Trail Table:** Har sensitive academic action (jaise Faculty ne kis student ka project kis date ko co-sign kiya, recruiter ne kis student ko invite bheja) ko dedicated `audit_logs` table me write karein.

SkillSync Nexus

Implementation Roadmap & Action Checklist

6. Phase 5: Legal, Compliance & Data Privacy

- **DPDP Act (India 2023) Compliance:** Student ki consent ke bina recruiter ko personal details (Phone, Personal Address) reveal na karein. Initial discovery phase me candidate anonymized benchmark profile dikhegi.
- **Explicit Consent Checkbox:** Registration par explicit disclaimer: *"I consent to SkillSync Nexus evaluating my academic records and project code for career matching."*
- **Right to be Forgotten:** Student dashboard me "Delete My Account & Purge Data" ka functional endpoint hona mandatory hai.
- **Data Encryption:** Data in transit ke liye TLS 1.3 aur data at rest ke liye AES-256 encryption.

7. Phase 6: DevOps, Testing & Containerization

- **Docker Multi-Stage Build:** Production container image ko Node-Alpine base image par build karein taaki image size < 150MB rahe aur dev-dependencies strip out ho jayein.
- **Automated Testing Suite:**
 - **Unit Tests (Vitest):** Matching algorithms aur NLP extraction logic ke 100% unit tests.
 - **API Integration Tests (Supertest):** Har route (`/api/students/:id/skills` , `/api/auth/login`) ke status code aur payload validation tests.
- **GitHub Actions CI/CD:** Har `git push origin main` par automatic linting, test suite execution, vulnerability audit (`npm audit`), aur zero-downtime deployment trigger ho.
- **Cloudflare Reverse Proxy:** Cloudflare WAF enable karein for DDoS protection, SSL termination, aur global edge caching.

8. Production Readiness Priority Matrix (Execution Order)

Priority	Task / Feature	Target Library / Tool	Estimated Effort
P0 - Day 1	Password Hashing & Salt	<code>bcrypt</code> / <code>argon2</code>	1 Day
P0 - Day 1	Auth Rate Limiting	<code>express-rate-limit</code>	0.5 Day
P0 - Day 1	HTTP Security Headers	<code>helmet</code>	2 Hours
P0 - Day 1	Strict Production CORS	<code>cors</code> whitelist	1 Hour
P1 - Week 1	HttpOnly Secure JWT Session	<code>cookie-parser</code> + JWT	2 Days
P1 - Week 1	Input Validation Middleware	<code>zod</code>	2 Days
P1 - Week 2	Database Indexing & PgBouncer	Supabase / PostgreSQL	1 Day
P1 - Week 2	Centralized Crash Reporting	<code>@sentry/node</code>	1 Day
P2 - Month 1	Redis Caching for Search	<code>ioredis</code>	3 Days

Priority	Task / Feature	Target Library / Tool	Estimated Effort
P2 - Month 1	S3 Presigned URL Uploads	@aws-sdk/s3	3 Days
P2 - Month 1	Multi-Factor Auth (MFA)	Supabase Auth TOTP	2 Days